

Welcome to

Introduction to Offensive Security

Saint Cyber – Cyber Akademiet, 2026

Henrik Kramselund he/him han/ham hlk@zencurity.com @kramse

Slides are available as PDF, https://codeberg.org/kramse
academy-2026-day0-intro.tex in the repo security-courses

© license CC BY 3.0. 2026 Henrik Kramselund

Goals for today



- Explain offensive security as an authorised simulation of adversary tools, tactics and techniques
- Distinguish vulnerability scanning, vulnerability management, penetration testing and simulated attack exercises
- Apply the core penetration-testing lifecycle (PTES)
- Define scope, objectives, testing conditions and rules of engagement before testing
- Assess vulnerability severity using CVSS and prioritise remediation

Plan for today



- What offensive security is – and authorised vs unauthorised
- The three types: vulnerability management & scanning, penetration testing, simulated attack exercises
- CVSS and risk-based prioritisation
- The penetration-testing lifecycle (PTES)
- Scope, rules of engagement and reporting

Time schedule



- **FIXME:** 1) What is offensive security + types – XX min
- **FIXME:** 2) CVSS + exercise – XX min
- **FIXME:** 3) PTES lifecycle – XX min
- **FIXME:** 4) Scope / rules of engagement + reporting – XX min

What is offensive security?



- **FIXME:** define offensive security (authorised, uses adversary TTPs, does not cause harm)
- **FIXME:** "to defeat a threat actor, you must think like a threat actor"
- **FIXME:** why it matters – tests the real effectiveness of the defences

Authorised vs unauthorised



- **FIXME:** what makes testing authorised (written permission, scope, ToE)
- **FIXME:** legal and ethical boundaries

The three types of offensive security



- Vulnerability management & scanning
- Penetration testing
- Simulated attack exercises

Vulnerability management & scanning



- **FIXME:** automated scanning vs the management process
- **FIXME:** tools you use + how often

Penetration testing



- **FIXME:** goal-driven, uses the same TTPs as a threat actor
- **FIXME:** scope and limitations

Simulated attack exercises



- **FIXME:** red team / purple team, stealth, assumed breach
- **FIXME:** how it differs from a pentest

CVSS – severity scoring



- **FIXME:** what CVSS is and the metric groups
- **FIXME:** how base vector maps to a score

Exercise: score a vulnerability with CVSS



- **FIXME:** choose a CVE
- **FIXME:** work out AV/AC/PR/UI/S/C/I/A and the score
- **FIXME:** discuss risk = likelihood x impact for prioritisation

Penetration-testing lifecycle (PTES)



- Pre-engagement interactions
- Intelligence gathering (reconnaissance)
- Threat modelling
- Vulnerability analysis
- Exploitation
- Post-exploitation
- Reporting

Pre-engagement: scope & rules of engagement



- **FIXME:** scope (what), objectives (why), conditions (when)
- **FIXME:** disallowed methods, prerequisites, signing the terms of engagement

Reconnaissance & intelligence gathering



- **FIXME:** OSINT, footprinting, active vs passive

Threat modelling



- **FIXME:** identify and categorise assets and threats; map threats to assets

Vulnerability analysis



- **FIXME:** automated + manual, list of high-value targets

Exploitation



- **FIXME:** exploit, gain access, consider countermeasures

Post-exploitation



- **FIXME:** value of the asset, data, pivoting, clean up

Reporting – technical & management audiences



- **FIXME:** executive summary vs technical description
- **FIXME:** findings, impact, prioritised recommendations

Exercise: define scope & rules of engagement



- **FIXME:** give the cadets a target and have them write scope + RoE

Summary & references



- **FIXME:** recap the three types + the PTES lifecycle
- *Web Application Security*, Andrew Hoffman, 2020, ISBN: 9781492053118 (WAS)
- **FIXME:** add any other references you use